

Third-Party AI Vendor Risk Questionnaire — Overview

Northstar FinTech Services Pvt. Ltd. (fictional organization, for portfolio purposes)

Prepared by: Nisarg Kamble | AI Governance Portfolio, Project 4 of 5 | September 2026

1. Purpose

This questionnaire is used to evaluate a third-party AI or AI-agent vendor before enterprise adoption, per Section 11 of Northstar’s Responsible AI Policy (Project 3 of this portfolio). It is framed as the questions an AI governance professional would ask when evaluating an AI/agent vendor — it does not represent official requirements of any specific vendor, and no real vendor is claimed to require or endorse it.

Sections K (AI Agent Permissions & Autonomy) and L (Prompt Injection / Adversarial Risks) draw on general AI-agent governance concepts — permission scoping, prompt-injection defense, data-handling guardrails — consistent with publicly documented approaches such as Salesforce’s Einstein Trust Layer for Agentforce, used as an illustrative reference point only. These two sections are asked as separate questions deliberately: the real, patched “ForcedLeak” vulnerability disclosed in Salesforce Agentforce (Noma Security, September 2025, CVSS 9.4) was not a failure of prompt-injection detection — it succeeded because the agent had broader read permissions and looser egress restrictions than it needed. A vendor can score well on prompt-injection defense and still be exploitable on permission scope; treating these as one combined question would hide that distinction.

2. Structure

The questionnaire (02_Template/Vendor_Risk_Questionnaire_Template.xlsx) is a five-tab working Excel tool, not a static form:

Tab	Contents
Instructions	Purpose, how to use the workbook, scoring methodology, decision bands, limitations
Vendor Profile	Vendor identity, use case, assessor, risk tier
Questionnaire	61 questions across 20 sections (A–T), covering governance, data, privacy, security, AI safety, model risk, bias/fairness, transparency, human oversight, agent permissions, adversarial risk, monitoring, incident management, model change management, subprocessors, retention, business continuity, regulatory compliance,

Tab	Contents
Scoring Summary	and assurance evidence Per-section Critical/High/Medium/Low/N/A severity input, with a live formula computing the overall rating and Final Decision
Red Flags	Nine specific conditions that force escalation to the AI Governance Committee regardless of the computed score

3. Scoring Methodology

Each section is scored by the assessor as Critical / High / Medium / Low gap severity, based on the completeness and verifiability of the evidence provided — not merely whether the vendor answered. The overall vendor rating is the **highest (most severe) individual section rating**, computed automatically via a formula, not averaged across sections. This “worst-of” methodology is a deliberate design choice: averaging would allow a severe governance or safety gap to be masked by strong performance elsewhere. The formula was tested directly — feeding a mix of Low/Medium/High/Critical section scores correctly returns the Critical overall rating, confirming the worst-of logic actually holds rather than silently falling back to an average.

Final Decision bands (computed automatically from the overall rating):

- **Approved** — Low overall rating; standard procurement process applies.
- **Approved with Conditions** — Medium overall rating; documented follow-up items with an assigned owner and review date.
- **Further Due Diligence Required** — High overall rating; AI Governance Committee review required before any deployment decision.
- **Further Due Diligence Required (Critical)** — Critical overall rating; AI Governance Committee review mandatory; becomes Rejected if unresolved after follow-up.

4. Red Flags

Nine specific responses (or non-responses) trigger mandatory escalation to the AI Governance Committee independent of the computed score — including undisclosed subprocessors, unrestricted agent permissions, no incident-notification process, and no data-deletion commitment. One red flag — “vendor cannot describe specific limits on what external destinations an agent is permitted to send data to” — was added directly as a result of researching the ForcedLeak incident (see 01_Research/reference_notes.md); it did not appear in the original draft of this questionnaire.

5. Worked Example

03_Worked_Example/Sample_Assessment_FictionalVendor.xlsx fills out the full template for a fictional vendor — CloudAgent Technologies Inc. and its “Aria” customer-support agent — with a realistic, deliberately mixed result rather than an all-Low showcase:

- Most sections score **Low or Medium**: governance, system documentation, security certifications, transparency, logging, subprocessor disclosure, and data retention are all solid.
- **Section K (Agent Permissions & Autonomy) scores High** — the vendor’s default permission template is broader than the use case needs, narrowing it isn’t self-service, and critically, the vendor could not describe a specific, documented mechanism limiting which external destinations the agent can send data to.
- This same underlying gap **independently triggers Red Flag #5**, producing a second, separate signal pointing at the same weakness — which is a stronger finding than either the score or the flag alone, and is exactly the kind of pattern a “worst-of” methodology plus a red-flag layer is designed to surface rather than let a vendor’s otherwise-strong profile mask.
- **Computed result: Overall Rating = High – Further Due Diligence Required**, with the AI Governance Committee escalation independently confirmed by the Red Flags tab.

This worked example demonstrates the tool functioning exactly as intended on a scenario built to resemble a real, plausible vendor gap — not a contrived edge case.

6. Limitations

This questionnaire is a screening tool; a satisfactory response to each question does not eliminate risk, and does not replace Northstar’s own testing described in Project 2 of this portfolio. This document is illustrative, built for a fictional organization, and does not reflect an actual completed vendor assessment. Regulatory questions (Section S) require review by Northstar’s Legal/Compliance function; this questionnaire does not constitute legal advice.

References

- National Institute of Standards and Technology. (2023). *AI Risk Management Framework (AI RMF 1.0)*.
- International Organization for Standardization / International Electrotechnical Commission. (2023). *ISO/IEC 42001:2023 — Information technology — Artificial intelligence — Management system*. Annex A includes a dedicated control objective for third-party and customer relationships, requiring documented role allocation and ongoing supplier monitoring with verifiable evidence — the basis for Section T (Assurance Evidence).
- Noma Security. (2025). *ForcedLeak: AI Agent Risks Exposed in Salesforce Agentforce* (CVSS 9.4, disclosed September 25, 2025) — the real, patched incident informing Sections K/L’s framing and Red Flag #5.
- Salesforce. *Einstein Trust Layer for Agentforce* (public documentation) — illustrative reference for mature agent-governance architecture (secure data retrieval, data masking, prompt-injection defense, audit trails).

Note on evidence verification: All sources above were independently checked against a live web search in September 2026, including the ForcedLeak incident details and ISO/IEC 42001’s

third-party control objective. See 01_Research/reference_notes.md for the full research trail.